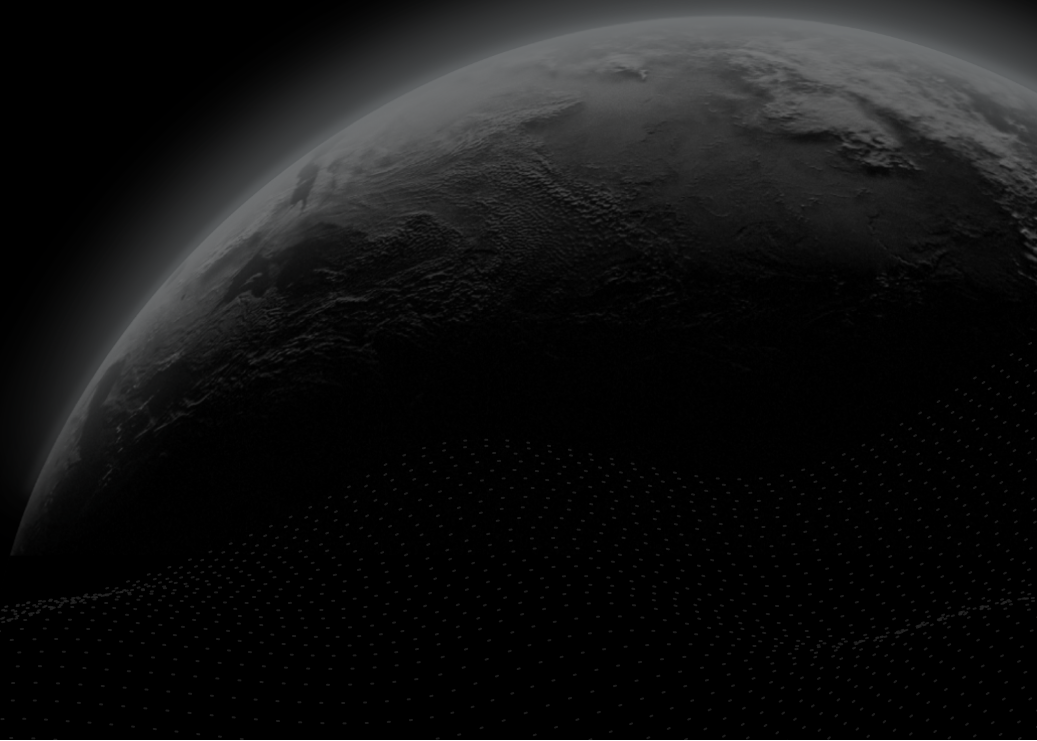
CERTIK

Security Assessment

STAIKA

CertiK Assessed on Mar 1st, 2023



CertiK Assessed on Mar 1st, 2023

STAIKA

The security assessment was prepared by CertiK, the leader in Web3.0 security.

Executive Summary

TYPES	ECOSYSTEM	METHODS
Token	Solana (SOL)	Manual Review, Static Analysis

LANGUAGE	TIMELINE	KEY COMPONENTS
Rust	Delivered on 03/01/2023	N/A

CODEBASE
https://github.com/stik-proj/mint-token
...View All

COMMITS
8d09328db3da689e8334e260d762e1ead8c60ea9
...View All

Vulnerability Summary



5	4	0	0	1	0
Total Findings	Resolved	Mitigated	Partially Resolved	Acknowledged	Declined

0	Critical		Critical risks are those that impact the safe functioning of a platform and must be addressed before launch. Users should not invest in any project with outstanding critical risks.
0	Major		Major risks can include centralization issues and logical errors. Under specific circumstances, these major risks can lead to loss of funds and/or control of the project.
0	Medium		Medium risks may not pose a direct risk to users' funds, but they can affect the overall functioning of a platform.
1	Minor	1 Resolved	Minor risks can be any of the above, but on a smaller scale. They generally do not compromise the overall integrity of the project, but they may be less efficient than other solutions.
4	Informational	3 Resolved, 1 Acknowledged	Informational errors are often recommendations to improve the style of the code or certain operations to fall within industry best practices. They usually do not affect the overall functioning of the code.

TABLE OF CONTENTS | STAIKA

Summary

- Executive Summary
- Vulnerability Summary
- Codebase
- Audit Scope
- Approach & Methods

System Overview

Review Notes

Findings

- CAR-01 : Outdated Dependencies
- MAI-01 : Clone On Copy
- MAI-02 : To String In Format Args
- MAI-03 : Unused Imports
- MAI-04 : Single Component Path Imports

Appendix

Disclaimer

CODEBASE | STAIKA

Repository

https://github.com/stik-proj/mint-token

Commit

8d09328db3da689e8334e260d762e1ead8c60ea9

AUDIT SCOPE | STAIKA

1 file audited ● 1 file with Acknowledged findings

ID	File	SHA256 Checksum
● MAI	src/main.rs	541220a524e701b162f76ee8f5b10918700bb83ec91b66782bea9274c0d5e7b1

APPROACH & METHODS | STAIKA

This report has been prepared for STAIKA to discover issues and vulnerabilities in the source code of the STAIKA project as well as any project dependencies that were not part of an officially recognized library. A comprehensive examination has been performed, utilizing Manual Review and Static Analysis techniques.

The auditing process pays special attention to the following considerations:

- Testing the project against both common and uncommon attack vectors.
- Assessing the codebase to ensure compliance with current best practices and industry standards.
- Ensuring project logic meets the specifications and intentions of the client.
- Thorough line-by-line manual review of the entire codebase by industry experts.

The security assessment resulted in findings that ranged from critical to informational. We recommend addressing these findings to ensure a high level of security standards and industry practices. We suggest recommendations that could better serve the project from the security perspective:

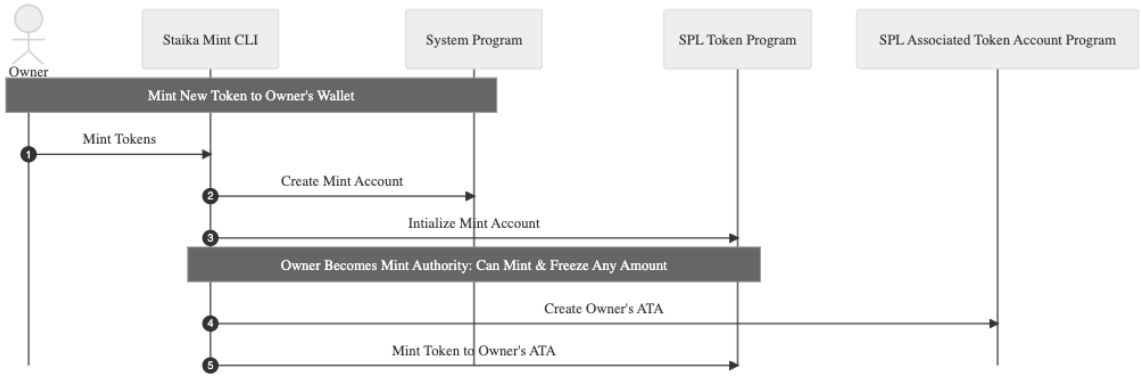
- Enhance general coding practices for better structures of source codes;
- Add enough unit tests to cover the possible use cases;
- Provide more comments per each function for readability, especially contracts that are verified in public;

SYSTEM OVERVIEW | STAIKA

The Staika mint token client goal is to help the team create and initialize a new token in the Solana blockchain, using the Solana Token Program.

Main Flow

The main flow is depicted in the following sequence diagram. The diagram highlights the various steps that are performed by the mint token client of Staika.



As we can see from the picture, the user (i.e., the Staika dev team) can call the mint token client providing an `owner` account that will be used as the authority of the new token mint, the amount of tokens that need to be minted and the decimals of the new token (step 1 in the figure). The mint token client will then create and send two instructions, first to the System Program to create the Mint account and second to the Solana Token Program to initialize the new Mint account (Steps 2 and 3). After that, the owner's associated token account (ATA) is created (step 4) to allow the owner to accumulate the newly created token. Finally, the mint token client will mint the specified amount of tokens to the owner's associated token account (Step 5).

REVIEW NOTES | STAIKA

The mint token client of the Staika project is a tool that implements the main instructions to use the Solana Token Program to create new tokens from command line. Therefore, it does not represent a Solana program as is.

Centralization-related Risks

The token created using the mint token client will be fully controlled by the `owner` indicated at creation, as the `owner` account will be the authority of the `mint-token`. As a result, any compromise to the `owner` account could allow a malicious actor to:

- Mint infinite tokens to arbitrary accounts to steal funds.
- Freeze any amount of token, locking the user's money at his will.

We highly recommend keeping the `owner` account safe, for example, using a multi-sig with enough participants or controlling the `owner` account using a DAO.

Moreover, we suggest being transparent with the community about the usage of the `owner` account.

FINDINGS | STAIKA



5	0	0	0	1	4
Total Findings	Critical	Major	Medium	Minor	Informational

This report has been prepared to discover issues and vulnerabilities for STAIKA. Through this audit, we have uncovered 5 issues ranging from different severity levels. Utilizing the techniques of Manual Review & Static Analysis to complement rigorous manual code reviews, we discovered the following findings:

ID	Title	Category	Severity	Status
CAR-01	Outdated Dependencies	Language Specific	Minor	Resolved
MAI-01	Clone On Copy	Coding Style	Informational	Resolved
MAI-02	To String In Format Args	Coding Style	Informational	Resolved
MAI-03	Unused Imports	Coding Style	Informational	Resolved
MAI-04	Single Component Path Imports	Coding Style	Informational	Acknowledged

CAR-01 | OUTDATED DEPENDENCIES

Category	Severity	Location	Status
Language Specific	Minor	Cargo.toml (base commit): 9~13, 16	Resolved

Description

Some of the dependencies used on the project are outdated.

The usage of yanked, outdated or vulnerable dependencies can lead to dangers not visualized on this audit because those dependencies could insert vulnerabilities on the codebase that were out of the scope, therefore not found.

Recommendation

We recommend analyzing the dependencies used by the project, checking that they don't contain vulnerabilities or missing features that can affect the program. Important to verify that the developers of the project were not using a different version of a dependency documentation or source code as a guide to develop the current code, this could lead to the assumption by some developers that some features are already implemented while they are not in the version of the dependency used the project.

If a dependency needs to hold an outdated version by any motived, justify and document the decision. We encourage the project to be always monitoring the state of the used dependencies, to prevent damage caused by zero-day vulnerabilities founded on the related dependencies.

Alleviation

`[Certik]`: The client heeded the advice and updated the dependencies versions on commit 8d09328db3da689e8334e260d762e1ead8c60ea9.

MAI-01 | CLONE ON COPY

Category	Severity	Location	Status
Coding Style	Informational	src/main.rs (base commit): 122	Resolved

Description

Pointed locations use `clone` on type `u64` which implements the `Copy` trait. The only reason the `clone` method is present in `copy` trait is for generics and is not intended to be used.

Recommendation

We recommend removing the `clone` call.

For further information visit https://rust-lang.github.io/rust-clippy/master/index.html#clone_on_copy

Alleviation

`[Certik]`: The client heeded the advice and removed the clone call on commit 8d09328db3da689e8334e260d762e1ead8c60ea9.

MAI-02 | TO STRING IN FORMAT ARGS

Category	Severity	Location	Status
Coding Style	Informational	src/main.rs (base commit): 55, 56, 69	Resolved

Description

The function `to_string()` is applied to a type that implements `display` in `println!` args. Since the type implements Display, the use of to_string is unnecessary.

Recommendation

Please, remove the `to_string()` call

For further information visit https://rust-lang.github.io/rust-clippy/master/index.html#to_string_in_format_args

Alleviation

`[Certik]`: The client removed the indicated `println!` completely in commit 8d09328db3da689e8334e260d762e1ead8c60ea9.

MAI-03 | UNUSED IMPORTS

Category	Severity	Location	Status
Coding Style	Informational	src/main.rs (base commit): 3, 5, 7, 9, 13, 16	Resolved

Description

Unused imports: `account`, `hash::hash`, `nonblocking::rpc_client::rpcclient as asyncrpcclient`, `pubkey::pubkey`, `system_instruction`, `transport::transporterror`.

Recommendation

We recommend removing the unused imports.

Alleviation

`[Certk]`: The client heeded the advice and resolved the issue in commit 8d09328db3da689e8334e260d762e1ead8c60ea9.

MAI-04 | SINGLE COMPONENT PATH IMPORTS

Category	Severity	Location	Status
Coding Style	Informational	src/main.rs (base commit): 15	Acknowledged

Description

The import at the pointed location is redundant.

Recommendation

We recommend removing the indicated import.

For further information visit https://rust-lang.github.io/rust-clippy/master/index.html#single_component_path_imports

Alleviation

[Certik] The client acknowledged the finding.

APPENDIX | STAIKA

Finding Categories

Categories	Description
Language Specific	Language Specific findings are issues that would only arise within Rust, e.g., Needless borrow.
Coding Style	Coding Style findings suggest how to increase the readability and, thus, the codebase's maintainability. Usually, they do not affect the generated byte code.

Checksum Calculation Method

The "Checksum" field in the "Audit Scope" section is calculated as the SHA-256 (Secure Hash Algorithm 2 with digest size of 256 bits) digest of the content of each file hosted in the listed source repository under the specified commit.

The result is hexadecimal encoded and is the same as the output of the Linux "sha256sum" command against the target file.

DISCLAIMER | CERTIK

This report is subject to the terms and conditions (including without limitation, description of services, confidentiality, disclaimer and limitation of liability) set forth in the Services Agreement, or the scope of services, and terms and conditions provided to you ("Customer" or the "Company") in connection with the Agreement. This report provided in connection with the Services set forth in the Agreement shall be used by the Company only to the extent permitted under the terms and conditions set forth in the Agreement. This report may not be transmitted, disclosed, referred to or relied upon by any person for any purposes, nor may copies be delivered to any other person other than the Company, without CertiK's prior written consent in each instance.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts CertiK to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. CertiK's position is that each company and individual are responsible for their own due diligence and continuous security. CertiK's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by CertiK is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis. Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

ALL SERVICES, THE LABELS, THE ASSESSMENT REPORT, WORK PRODUCT, OR OTHER MATERIALS, OR ANY PRODUCTS OR RESULTS OF THE USE THEREOF ARE PROVIDED "AS IS" AND "AS AVAILABLE" AND WITH ALL FAULTS AND DEFECTS WITHOUT WARRANTY OF ANY KIND. TO THE MAXIMUM EXTENT PERMITTED UNDER APPLICABLE LAW, CERTIK HEREBY DISCLAIMS ALL WARRANTIES, WHETHER EXPRESS, IMPLIED, STATUTORY, OR OTHERWISE WITH RESPECT TO THE SERVICES, ASSESSMENT REPORT, OR OTHER MATERIALS. WITHOUT LIMITING THE FOREGOING, CERTIK SPECIFICALLY DISCLAIMS ALL IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, TITLE AND NON-INFRINGEMENT, AND ALL WARRANTIES ARISING FROM COURSE OF DEALING, USAGE, OR TRADE PRACTICE. WITHOUT LIMITING THE FOREGOING, CERTIK MAKES NO WARRANTY OF ANY KIND THAT THE SERVICES, THE LABELS, THE ASSESSMENT REPORT, WORK PRODUCT, OR OTHER MATERIALS, OR ANY PRODUCTS OR RESULTS OF THE USE THEREOF, WILL MEET CUSTOMER'S OR ANY OTHER PERSON'S REQUIREMENTS, ACHIEVE ANY INTENDED RESULT, BE COMPATIBLE OR WORK WITH ANY SOFTWARE, SYSTEM, OR OTHER SERVICES, OR BE SECURE, ACCURATE, COMPLETE, FREE OF HARMFUL CODE, OR ERROR-FREE. WITHOUT LIMITATION TO THE FOREGOING, CERTIK PROVIDES NO WARRANTY OR

UNDERTAKING, AND MAKES NO REPRESENTATION OF ANY KIND THAT THE SERVICE WILL MEET CUSTOMER'S REQUIREMENTS, ACHIEVE ANY INTENDED RESULTS, BE COMPATIBLE OR WORK WITH ANY OTHER SOFTWARE, APPLICATIONS, SYSTEMS OR SERVICES, OPERATE WITHOUT INTERRUPTION, MEET ANY PERFORMANCE OR RELIABILITY STANDARDS OR BE ERROR FREE OR THAT ANY ERRORS OR DEFECTS CAN OR WILL BE CORRECTED.

WITHOUT LIMITING THE FOREGOING, NEITHER CERTIK NOR ANY OF CERTIK'S AGENTS MAKES ANY REPRESENTATION OR WARRANTY OF ANY KIND, EXPRESS OR IMPLIED AS TO THE ACCURACY, RELIABILITY, OR CURRENCY OF ANY INFORMATION OR CONTENT PROVIDED THROUGH THE SERVICE. CERTIK WILL ASSUME NO LIABILITY OR RESPONSIBILITY FOR (I) ANY ERRORS, MISTAKES, OR INACCURACIES OF CONTENT AND MATERIALS OR FOR ANY LOSS OR DAMAGE OF ANY KIND INCURRED AS A RESULT OF THE USE OF ANY CONTENT, OR (II) ANY PERSONAL INJURY OR PROPERTY DAMAGE, OF ANY NATURE WHATSOEVER, RESULTING FROM CUSTOMER'S ACCESS TO OR USE OF THE SERVICES, ASSESSMENT REPORT, OR OTHER MATERIALS.

ALL THIRD-PARTY MATERIALS ARE PROVIDED "AS IS" AND ANY REPRESENTATION OR WARRANTY OF OR CONCERNING ANY THIRD-PARTY MATERIALS IS STRICTLY BETWEEN CUSTOMER AND THE THIRD-PARTY OWNER OR DISTRIBUTOR OF THE THIRD-PARTY MATERIALS.

THE SERVICES, ASSESSMENT REPORT, AND ANY OTHER MATERIALS HEREUNDER ARE SOLELY PROVIDED TO CUSTOMER AND MAY NOT BE RELIED ON BY ANY OTHER PERSON OR FOR ANY PURPOSE NOT SPECIFICALLY IDENTIFIED IN THIS AGREEMENT, NOR MAY COPIES BE DELIVERED TO, ANY OTHER PERSON WITHOUT CERTIK'S PRIOR WRITTEN CONSENT IN EACH INSTANCE.

NO THIRD PARTY OR ANYONE ACTING ON BEHALF OF ANY THEREOF, SHALL BE A THIRD PARTY OR OTHER BENEFICIARY OF SUCH SERVICES, ASSESSMENT REPORT, AND ANY ACCOMPANYING MATERIALS AND NO SUCH THIRD PARTY SHALL HAVE ANY RIGHTS OF CONTRIBUTION AGAINST CERTIK WITH RESPECT TO SUCH SERVICES, ASSESSMENT REPORT, AND ANY ACCOMPANYING MATERIALS.

THE REPRESENTATIONS AND WARRANTIES OF CERTIK CONTAINED IN THIS AGREEMENT ARE SOLELY FOR THE BENEFIT OF CUSTOMER. ACCORDINGLY, NO THIRD PARTY OR ANYONE ACTING ON BEHALF OF ANY THEREOF, SHALL BE A THIRD PARTY OR OTHER BENEFICIARY OF SUCH REPRESENTATIONS AND WARRANTIES AND NO SUCH THIRD PARTY SHALL HAVE ANY RIGHTS OF CONTRIBUTION AGAINST CERTIK WITH RESPECT TO SUCH REPRESENTATIONS OR WARRANTIES OR ANY MATTER SUBJECT TO OR RESULTING IN INDEMNIFICATION UNDER THIS AGREEMENT OR OTHERWISE.

FOR AVOIDANCE OF DOUBT, THE SERVICES, INCLUDING ANY ASSOCIATED ASSESSMENT REPORTS OR MATERIALS, SHALL NOT BE CONSIDERED OR RELIED UPON AS ANY FORM OF FINANCIAL, TAX, LEGAL, REGULATORY, OR OTHER ADVICE.

CertiK | Securing the Web3 World

Founded in 2017 by leading academics in the field of Computer Science from both Yale and Columbia University, CertiK is a leading blockchain security company that serves to verify the security and correctness of smart contracts and blockchain-based protocols. Through the utilization of our world-class technical expertise, alongside our proprietary, innovative tech, we're able to support the success of our clients with best-in-class security, all whilst realizing our overarching vision; provable trust for all throughout all facets of blockchain.

